

Programa de Adiestramiento Experto: Identidad Digital, Autenticación y Autorización en Sistemas de Software

CICLO FORMATIVO: Especializado (X) ¹

DURACIÓN TOTAL: 20 Horas (14 Horas de Sesiones de Diseño/Teoría + 6 Horas de Laboratorios Prácticos)

REQUISITO CURRICULAR: Conocimientos previos en redes, seguridad informática, APIs REST y fundamentos de desarrollo de software.²

Módulo 1: Arquitectura de Confianza Cero y Gobierno del Ciclo de Vida (5 Horas)

Descripción del Módulo

Este módulo inicial introduce la identidad digital como el plano de control primario e insustituible en las arquitecturas modernas de Confianza Cero (Zero Trust), sustituyendo de forma definitiva el antiguo concepto de seguridad perimetral basada en redes.³ Los estudiantes comprenderán de manera holística el modelo IAAA (Identificación, Autenticación, Autorización y Contabilidad) y aprenderán a diferenciar las necesidades de escala y seguridad de los entornos internos corporativos (Workforce IAM) frente a las demandas de experiencia de usuario y privacidad en portales orientados a clientes masivos (CIAM).² Asimismo, se analizará de forma exhaustiva el ciclo de vida completo de un usuario bajo el patrón Joiner-Mover-Leaver (JML), diseñando estrategias defensivas para evitar fallas críticas de seguridad como la acumulación silenciosa de privilegios (privilege creep) y asegurar la segregación de funciones mediante el modelado técnico de políticas de acceso estáticas (RBAC) y dinámicas (ABAC).²

Temario Detallado

- **1.1. Arquitectura Zero Trust:** Desplazamiento de los límites perimetrales. Señales de contexto continuo (IP, dispositivo, comportamiento del usuario, telemetría de riesgo) y el principio de verificación explícita.⁶
- **1.2. El Modelo IAAA en Sistemas Distribuidos:** Flujos lógicos paso a paso para establecer transacciones de acceso auditables.²
- **1.3. Modelado de Identidades:** Taxonomía de la identidad física, burocrática y digital funcional. Atributos inherentes, acumulados y asignados.⁸
- **1.4. Gobierno del Ciclo de Vida del Usuario (JML):** Procesos de aprovisionamiento y desaprovisionamiento automatizados. Mitigación de cuentas huérfanas y dormant accounts.
- **1.5. Modelos de Autorización Aplicada:** Diseño de matrices de control de accesos basados en roles (RBAC), atributos basados en el contexto (ABAC) y políticas dinámicas (PBAC).²
- **1.6. Práctica Guiada (Laboratorio 1):** Despliegue de Keycloak en contenedores Docker. Configuración de Realms de seguridad independientes, diseño de grupos de usuarios y

asignación jerárquica de roles RBAC.⁹

Módulo 2: Autenticación Robusta y Criptografía Web (3 Horas)

Descripción del Módulo

La autenticación de identidades humanas ha evolucionado drásticamente para contrarrestar la ineficacia de las contraseñas estáticas y los esquemas tradicionales de segundo factor que son vulnerables a ataques dirigidos.¹⁰ En este módulo, los profesionales analizarán de forma crítica las debilidades de los mecanismos de autenticación tradicionales, incluyendo la suplantación de identidad en redes móviles (SIM swapping) y el phishing de tiempo de ejecución mediante ataques de fatiga push.² A partir de esta base diagnóstica, el contenido profundiza en los fundamentos criptográficos de clave pública de la FIDO Alliance y la especificación WebAuthn del W3C.¹¹ Se capacitará a los estudiantes para diseñar e implementar flujos passwordless y passkeys corporativas integradas en el hardware seguro de los dispositivos de los usuarios, garantizando una defensa inquebrantable frente al phishing y reduciendo a cero la superficie de ataque por robo de credenciales.¹¹

Temario Detallado

- **2.1. Vulnerabilidades de Autenticación:** Fallas de factores débiles (SMS, OTP) y el auge del bypass de MFA interactivo por fatiga.
- **2.2. El Estándar FIDO2 y WebAuthn:** Criptografía asimétrica aplicada. Flujo clásico de comunicación entre navegadores y dispositivos de autenticación físicos o locales (CTAP1/CTAP2).¹¹
- **2.3. Passkeys Corporativas y Modelos Passwordless:** Registros de pares de llaves y autenticación biométrica vinculada a dominios de origen (origin-binding).¹⁴
- **2.4. Políticas de Acceso Condicional:** Elevación de autenticación en tiempo real (Step-up authentication) basada en disparadores de riesgo.⁷
- **2.5. Práctica Guiada (Laboratorio 2):** Implementación de una rutina de inicio de sesión passwordless nativa en un backend web usando APIs WebAuthn, validando el desafío (*challenge*) y la firma del autenticador local.¹¹

Módulo 3: Federación, JWT y Autenticación en Microservicios (6 Horas)

Descripción del Módulo

El auge de las aplicaciones web modernas y las arquitecturas distribuidas basadas en microservicios exige protocolos estandarizados para delegar la autorización y federar identidades sin comprometer la seguridad de las APIs.¹⁵ Este módulo técnico, de carácter central, desglosa los estándares OAuth 2.1 y OpenID Connect (OIDC), enseñando a los desarrolladores a construir flujos de autorización seguros basados en el patrón de código de autorización reforzado con PKCE (Proof Key for Code Exchange).¹⁶ Se abordan en profundidad los patrones de seguridad indispensables para microservicios, como la autenticación perimetral en el API Gateway, la traducción de tokens de referencia opacos a JSON Web Tokens firmados (Phantom Token Pattern) y la mitigación de ataques XSS en frontends JavaScript mediante la

implementación de Backend for Frontend (BFF).¹⁵ Finalmente, se realiza un análisis forense de tokens JWT, identificando vulnerabilidades de confusión de algoritmo y uso del algoritmo deshabilitado (alg: none), y aplicando defensas avanzadas como tokens restringidos por emisor mediante mTLS y firmas en tránsito DPoP (Demonstrating Proof-of-Possession).¹⁸

Temario Detallado

- **3.1. Delegación de Autorización con OAuth 2.1:** Roles, flujos de concesión de credenciales y eliminación de flujos vulnerables (Implicit flow y Resource Owner Password Credentials).
- **3.2. Federación de Identidad con OIDC:** Claims, Scopes, ID Tokens y uso del endpoint de información de usuario (UserInfo).¹⁹
- **3.3. Arquitectura de Seguridad en Microservicios:** Edge Authentication en API Gateways y el patrón de traducción de tokens (Phantom Tokens) para proteger la privacidad interna.
- **3.4. Patrón Backend for Frontend (BFF):** Almacenamiento seguro de credenciales y mitigación de XSS mediante el uso de cookies HttpOnly, Secure y SameSite.
- **3.5. Anatomía, Estructura y Firma de JWT:** Encabezado, Cargas Útiles, Firmas Simétricas (HS256) vs Asimétricas (RS256/ES256) e integración de endpoints JWKS.¹⁵
- **3.6. Seguridad Ofensiva de Tokens:** Mitigación del exploit alg: none, ataques de confusión de algoritmo, y esquemas de revocación en clústeres Redis mediante identificadores JTI.
- **3.7. Sender-Constrained Tokens:** Criptografía de posesión de clave con DPoP y mTLS para evitar ataques de replay de tokens robados.¹⁸
- **3.8. Práctica Guiada (Laboratorio 3):** Implementación paso a paso de una autenticación SPA segura utilizando el flujo Authorization Code con PKCE frente a Keycloak.¹⁶ El challenge criptográfico del verifier se calculará bajo la siguiente relación matemática:

$$Challenge = BASE64URL - ENCODE(SHA256(Verifier))$$

- **3.9. Práctica Guiada (Laboratorio 4):** Despliegue de un API Gateway y configuración de un proxy reverso que realice validación de tokens opacos, interroge al IdP mediante introspección y transmita cabeceras de tokens JWT firmados de forma transparente a microservicios *downstream*.

Módulo 4: Gobierno de Accesos Privilegiados (PAM) y Máquinas (3 Horas)

Descripción del Módulo

Las cuentas de administración y las identidades de máquina representan los objetivos más valiosos para los atacantes que buscan realizar movimientos laterales y comprometer infraestructuras críticas.²⁰ Este módulo capacita a los profesionales en las disciplinas complementarias de Gobierno de Identidad (IGA) y Gestión de Accesos Privilegiados (PAM), centrándose en el desmantelamiento de los privilegios administrativos permanentes (standing privileges).² Los alumnos aprenderán a diseñar e implementar flujos de trabajo de acceso Just-

in-Time (JIT) y de mínimo privilegio Just-Enough Access (JEA), asegurando que los privilegios elevados se otorguen bajo flujos de aprobación específicos y de forma estrictamente acotada en el tiempo.² Se estudiará también la gobernanza y rotación de credenciales no humanas (NHI) —como secretos de APIs, claves de sistemas de CI/CD y certificados de servicio— mediante gestores de secretos centralizados y bóvedas criptográficas.²⁰

Temario Detallado

- **4.1. Gobierno de la Identidad Administrativa (IGA):** Certificaciones periódicas de acceso, auditorías automatizadas y atestación de privilegios.²
- **4.2. Estrategias Privilegiadas (PAM):** Conceptos de bóvedas de contraseñas, proxies de sesión administrativa, grabación y auditoría de consolas de comandos.²¹
- **4.3. Acceso Dinámico (JIT y JEA):** Modelado de elevaciones temporales efímeras de privilegios y eliminación de cuentas de superusuario estáticas.²
- **4.4. Identidades No Humanas (NHI):** Clasificación, inventario, riesgos de credenciales expuestas en código y uso de identidades gestionadas en nubes híbridas.²⁰
- **4.5. Práctica Guiada (Laboratorio 5):** Configuración de una política PIM (Privileged Identity Management) para exigir justificación interactiva, MFA de segundo factor y programar la expiración automática de accesos elevados.²

Módulo 5: El Futuro de la Identidad: Identidad Soberana y eIDAS 2.0 (3 Horas)

Descripción del Módulo

La descentralización y la privacidad desde el diseño son los pilares que definen el futuro de las identidades digitales a nivel global.²⁴ Este módulo capacita a los estudiantes en el revolucionario paradigma de la Identidad Soberana (SSI), analizando el fin de la dependencia de proveedores centralizados y silos de datos.²⁴ Se profundizará en el nuevo reglamento europeo eIDAS 2.0 (Reglamento UE 2024/1183) y la inminente obligación del despliegue de la Cartera de Identidad Digital de la UE (EUDI Wallet).¹⁴ Los estudiantes dominarán la arquitectura del "triángulo de confianza" y aprenderán la implementación técnica de Credenciales Verificables utilizando formatos modernos como **SD-JWT** (Selective Disclosure JWT) para permitir la divulgación selectiva de atributos y proteger la privacidad de los datos personales de los ciudadanos.²⁶

Temario Detallado

- **5.1. Paradigma de la Identidad Soberana (SSI):** Decentralized Identifiers (DIDs), documentos DID, persistencia criptográfica y resolución de DIDs en registros verificables.²⁴
- **5.2. El Reglamento eIDAS 2.0 y la EUDI Wallet:** Objetivos de interoperabilidad de la Comisión Europea, plazos de cumplimiento para el sector público y privado, y el despliegue del proyecto Cartera Digital Beta en España.¹⁴
- **5.3. Criptografía de Credenciales Verificables (VCs):** Formatos de intercambio y la arquitectura de firmas de atestaciones electrónicas cualificadas de atributos (QEAA).¹⁴
- **5.4. Divulgación Selectiva con SD-JWT:** Compartición segura de subconjuntos de datos (p. ej., verificar mayoría de edad sin revelar fecha de nacimiento).²⁸

- **5.5. Interacción del Wallet con Relying Parties:** Implementación del protocolo **OpenID for Verifiable Presentations (OpenID4VP)** para solicitudes y presentaciones interactivas de credenciales.
- **5.6. Práctica Guiada (Laboratorio 6):** Emisión y firma de una credencial en formato SD-JWT utilizando un SDK descentralizado, y configuración de un verificador interactivo compatible con OpenID4VP.

Cronograma Temporal de Ejecución (20 Horas)

Este cronograma distribuye la formación de manera secuencial a lo largo de 7 sesiones teóricas e instructivas y 6 laboratorios prácticos e individuales, asegurando una progresión pedagógica óptima.²

Hora	Formato	Módulo	Contenido Específico / Actividad	Entregable o Práctica Asociada
H1	Teoría	Módulo 1	Identidad como plano de control y modelos de Zero Trust en sistemas distribuidos. ³	Análisis conceptual de señales condicionales.
H2	Teoría	Módulo 1	Taxonomía de identidades, modelo IAAA y diferencias entre Workforce IAM y CIAM. ²	Casos de estudio organizacionales.
H3	Teoría	Módulo 1	Gobernanza del ciclo de vida del usuario (JML) y diseño de políticas RBAC/ABAC/PBAC. ²	Ejercicios de modelado de matrices de acceso.
H4	Práctica	Módulo 1	Laboratorio 1: Despliegue de	Despliegue exitoso de

			servidor de identidad local e implementación de Realms y jerarquías. ⁹	Keycloak mediante Docker. ⁹
H5	Teoría	Módulo 2	Fallas de autenticación tradicionales, phishing interactivo y vulnerabilidades MFA.	Análisis de vectores de ataque por ingeniería social.
H6	Teoría	Módulo 2	Criptografía asimétrica aplicada, estándar FIDO2, especificaciones WebAuthn y Passkeys. ¹¹	Modelado de flujos de aserción criptográfica.
H7	Práctica	Módulo 2	Laboratorio 2: Desarrollo de endpoints WebAuthn del lado del servidor para flujos passwordless. ¹¹	Servicio funcional de validación de passkeys local. ¹¹
H8	Teoría	Módulo 3	Delegación de autorización mediante OAuth 2.1, scopes de APIs y flujos de login seguros.	Definición de roles de OAuth y scopes de API.

H9	Teoría	Módulo 3	Federación de identidades con OpenID Connect y diseño de inicio de sesión único (SSO).	Mapeo de claims en tokens de OIDC.
H10	Práctica	Módulo 3	Laboratorio 3: Integración de una SPA con Keycloak usando flujos con PKCE interactivos. ¹⁶	Código cliente JavaScript con PKCE funcional. ¹⁶
H11	Teoría	Módulo 3	Arquitecturas de seguridad en microservicios: BFF, validación perimetral y traducción de tokens.	Análisis de tráfico de microservicios (Este-Oeste).
H12	Teoría	Módulo 3	Deep Dive en JWT: distribución de claves JWKS, ataques comunes, DPOP y mitigaciones. ¹⁵	Diseño de políticas defensivas contra robos de tokens.
H13	Práctica	Módulo 3	Laboratorio 4: Configuración de API Gateway para validación de JWT e introspección	API Gateway funcional traduciendo Phantom Tokens.

			de tokens opacos.	
H14	Teoría	Módulo 4	Seguridad en cuentas críticas de administración, modelos de proxying de sesiones y arquitecturas PAM. ²¹	Diseño de perfiles de cuentas administrativas .
H15	Teoría	Módulo 4	Eliminación de standing privileges mediante accesos efímeros JIT y gobernanza de secretos de máquina (NHI). ²	Evaluación de riesgos en secretos hardcodeados.
H16	Práctica	Módulo 4	Laboratorio 5: Configuración de flujos de aprobación interactivos y ventanas temporales de acceso PIM. ²	Implementación y prueba de elevación temporal JIT. ²
H17	Teoría	Módulo 5	Limitaciones de la identidad federada clásica y fundamentos de la Identidad Soberana (SSI). ²⁴	Mapeo de DID's y llaves criptográficas.

H18	Teoría	Módulo 5	Atestaciones electrónicas de atributos (QEAA), reglamento eIDAS 2.0 y el EUDI Wallet europeo. ¹⁴	Casos de uso del EUDI Wallet en sectores regulados.
H19	Teoría	Módulo 5	Criptografía SD-JWT para divulgación selectiva y el protocolo de presentación OpenID4VP. ²⁸	Diseño de plantillas de credenciales SD-JWT.
H20	Práctica	Módulo 5	Laboratorio 6: Simulación interactiva de emisión de VCs y verificación selectiva con OpenID4VP.	Flujo SSI de verificación con preservación de privacidad.

Metodología de Evaluación y Certificación

La evaluación del programa se rige bajo una rúbrica de nivel experto que valora las capacidades analíticas y las destrezas de implementación práctica desarrolladas:²

- **Portafolio de Laboratorios (60% de la nota final):** Compilación y entrega de la documentación de los 6 entornos prácticos implementados de forma individual.²⁹
- **Proyecto Capstone de Fin de Curso (40% de la nota final):** Diseño e implementación de una arquitectura integral de seguridad de identidad para un ecosistema empresarial híbrido que contenga usuarios humanos externos, APIs de microservicios protegidos por API Gateway y el soporte para carteras de identidad digital de eIDAS 2.0.²⁹

Rúbrica de evaluación para la obtención de la certificación

Dimensión	Nivel Excelente (A)	Nivel Adecuado (B)	Nivel Insuficiente (C)
-----------	---------------------	--------------------	------------------------

Seguridad de Autenticación	Implementa esquemas resistentes al phishing (FIDO2/Passkeys) con políticas condicionales contextuales de Zero Trust. ¹⁴	Implementa MFA robusto pero mantiene dependencias de factores tradicionales vulnerables a ingeniería social.	Depende exclusivamente de contraseñas estáticas simples o MFA débil (SMS OTP). ¹⁴
Seguridad en APIs y Microservicios	Diseña arquitecturas JWT asimétricas validadas por JWKS en API Gateways con protecciones de tokens DPoP o mTLS.	Aplica flujos OAuth funcionales en el Gateway pero sin mitigación de robos de tokens (falta DPoP/mTLS).	Usa tokens desprotegidos expuestos en el frontend o firmas simétricas HS256 compartidas.
Gobernanza y PAM	Elimina privilegios permanentes implementando flujos de aprobación y accesos efímeros Just-in-Time (JIT). ²⁰	Asigna cuentas de administración permanentes aisladas pero carece de rotación dinámica de secretos.	Muestra acumulación progresiva de permisos (<i>privilege creep</i>) y nula segregación de funciones.
Identidad Soberana (SSI)	Utiliza el protocolo OpenID4VP con credenciales SD-JWT para divulgación selectiva y preservación de privacidad. ¹⁴	Aplica mecanismos de federación de credenciales descentralizadas sin control de divulgación selectiva.	No es capaz de estructurar un flujo de presentación interactivo o viola principios de minimización de datos. ¹⁴

1

Obras citadas

1. 7 Identidad Digital asociado a la autenticación y la autorización programa tentavio.pdf

2. IAM + PKI: Gestión y prácticas avanzadas de Identidad y Acceso ..., fecha de acceso: mayo 5, 2026, <https://pkimaster.com/course/pkimaster-curso-iam-pki/>
3. Identity and Access Management Workshop - WWT, fecha de acceso: mayo 5, 2026, <https://www.wwt.com/workshop/identity-and-access-management-workshop>
4. Customer Identity and Access Management - Curity, fecha de acceso: mayo 5, 2026, <https://curity.io/resources/ciam/>
5. Customer Identity and Access Management (CIAM) - Thales CPL, fecha de acceso: mayo 5, 2026, <https://cpl.thalesgroup.com/access-management/customer-identity>
6. Identity and Access Management | Instructor-Led Training | Pluralsight, fecha de acceso: mayo 5, 2026, <https://www.pluralsight.com/professional-services/security/identity-and-access-management>
7. What Is CIAM (Customer Identity and Access Management)? - Palo Alto Networks, fecha de acceso: mayo 5, 2026, <https://www.paloaltonetworks.com/cyberpedia/what-is-ciam>
8. OWASP 2023 TOP 10 API Vulnerabilities and mitigations, fecha de acceso: mayo 5, 2026, <https://owasp.org/www-chapter-sofia/assets/presentations/202412%20-%20OWASP%20Top%2010%20attacks%20&%20defenses%20by%20Nikolay%20Dimitrov.pdf>
9. A Practical Guide to Keycloak, OAuth2, and OpenID Connect for ..., fecha de acceso: mayo 5, 2026, <https://medium.com/@mk.muhammadkhourudin/a-practical-guide-to-keycloak-oauth2-and-openid-connect-for-developers-57453075b6ae>
10. Cyber Security Awareness Assessment Checklist - TitanHQ, fecha de acceso: mayo 5, 2026, <https://www.titanhq.com/cyber-security-awareness-assessment-checklist/>
11. WebAuthn Guide, fecha de acceso: mayo 5, 2026, <https://webauthn.guide/>
12. Lab - Authentication with FIDO2 | João Paulo Barraca, fecha de acceso: mayo 5, 2026, <https://sweet.ua.pt/jpbarraca/course/sio/lab-fido2/>
13. Build your first WebAuthn app - Google for Developers, fecha de acceso: mayo 5, 2026, <https://developers.google.com/codelabs/webauthn-reauth>
14. eIDAS 2.0 & the EUDI Wallet: A Practical Guide for Enterprise IAM ..., fecha de acceso: mayo 5, 2026, <https://www.wpass.com/blog/eidas-2-0-the-eudi-wallet-a-practical-guide-for-enterprise-iam-2025-2027/>
15. Getting Started with OAuth and OpenID Connect | Courses - Curity, fecha de acceso: mayo 5, 2026, <https://curity.io/resources/webinars/course-getting-started-with-oauth-and-openid-connect/>
16. OAuth 2.0 Authentication Vulnerabilities | by The4v1 | Apr, 2026 | Medium, fecha de acceso: mayo 5, 2026, <https://medium.com/@The4v1/oauth-2-0-authentication-vulnerabilities-f810876c21eb>
17. Testing for OAuth Client Weaknesses - WSTG - Latest | OWASP Foundation, fecha de acceso: mayo 5, 2026, https://owasp.org/www-project-web-security-testing-guide/latest/4-Web_Application_Security_Testing/05-Authorization_Testing/05.2-Testing_for_OAuth_Client_Weaknesses
18. OAuth 2.0 Protocol Cheatsheet - OWASP Cheat Sheet Series, fecha de acceso: mayo 5, 2026,

- https://cheatsheetseries.owasp.org/cheatsheets/OAuth2_Cheat_Sheet.html
19. Understanding OAuth 2.0 and OpenID Connect for Developers - OneUptime, fecha de acceso: mayo 5, 2026, <https://oneuptime.com/blog/post/2026-02-20-oauth2-oidc-explained/view>
 20. The Practitioner's Guide to Non-Human Identities | IBM, fecha de acceso: mayo 5, 2026, <https://www.ibm.com/think/insights/non-human-identity-guide>
 21. BeyondTrust Privileged Access Management (PAM) Training - myTectra, fecha de acceso: mayo 5, 2026, <https://www.mytectra.com/beyondtrust-privileged-access-management-pam-training>
 22. BeyondTrust Privileged Access Management Training | Online Course - Iteanz Technologies, fecha de acceso: mayo 5, 2026, <https://www.iteanz.com/beyondtrust-privileged-access-management-training>
 23. Implement privileged access management - Training - Microsoft Learn, fecha de acceso: mayo 5, 2026, <https://learn.microsoft.com/en-us/training/modules/m365-compliance-insider-implement-privileged-access-management/>
 24. Self-Sovereign Identity: The Ultimate Guide 2026 - Dock Labs, fecha de acceso: mayo 5, 2026, <https://www.dock.io/post/self-sovereign-identity>
 25. Identiverse 2025 / Personal Identity Workshop, fecha de acceso: mayo 5, 2026, <https://identiverse.com/idv25/personal-identity-workshop/>
 26. animo/awesome-self-sovereign-identity - GitHub, fecha de acceso: mayo 5, 2026, <https://github.com/animo/awesome-self-sovereign-identity>
 27. Self-Sovereign Identity on Oracle Blockchain with Privacy-Enhanced Verifiable Credentials, fecha de acceso: mayo 5, 2026, <https://blogs.oracle.com/blockchain/privacyenhanced-verifiable-credentials>
 28. Identity Management Institute | IMI, fecha de acceso: mayo 5, 2026, <https://identitymanagementinstitute.org/>
 29. 10 IAM Analyst Projects to Boost Your Skills and Resume, fecha de acceso: mayo 5, 2026, <https://artempolynko.com/blog/10-iam-analyst-resume-projects/>